

Playbook de Análisis Forense

Guía detallada de investigación y correlación MITRE basada en hallazgos SSH

Generado automáticamente por GoAudit

Fecha: 08/03/2026

Índice

- ✓ 1 — WeakCiphers
- ✓ 2 — PermitRootLogin
- ✓ 3 — UsePAM
- ✓ 4 — KexAlgorithms

Playbook de Hallazgos

WeakCiphers

Descripción ampliada

El uso de cifrados débiles o CBC en SSH aumenta la probabilidad de ataques MITM y de descifrado parcial del tráfico. Es una vulnerabilidad seria en entornos corporativos.

Importancia defensiva

Los cifrados CBC son débiles frente a ataques conocidos.

Evidencia

Se encontró el cipher inseguro: aes128-cbc

Explotación del hallazgo

Un adversario puede realizar ataques de downgrade, interceptar tráfico o manipular la negociación del cifrado para obtener información sensible.

MITRE ATT&CK

ID	Técnica	Táctica
T1557	Adversary-in-the-Middle	Credential Access, Collection
T1040	Network Sniffing	Credential Access, Discovery

Cyber Kill Chain

Fase
Reconnaissance
Weaponization
Exploitation

Indicadores DFIR

Tipo	Detalles
Logs relacionados	/var/log/auth.log
Artefactos clave	- Negociación de cifrados débiles. - Mensajes de error relacionados con MAC o algoritmos inseguros.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

PermitRootLogin

Descripción ampliada

Habilitar el acceso directo al usuario root permite a un atacante obtener control total del sistema sin requerir escalada de privilegios. Este es uno de los fallos más críticos en cualquier sistema Linux.

Importancia defensiva

Evita accesos directos al usuario root.

Evidencia

```
Línea 135: PermitRootLogin yes
```

Explotación del hallazgo

Un atacante puede intentar credenciales filtradas, débiles o comunes para obtener acceso directo como root, sin necesidad de escalar privilegios.

MITRE ATT&CK

ID	Técnica	Táctica
T1078	Valid Accounts	Initial Access, Persistence, Privilege Escalation, Defense Evasion
T1110	Brute Force	Credential Access
T1021.004	Remote Services: SSH	Lateral Movement

Cyber Kill Chain

Fase
Reconnaissance
Exploitation
Installation
Command & Control

Indicadores DFIR

Tipo	Detalles
Logs relacionados	/var/log/auth.log /var/log/secure
	Accesos root desde IPs externas.

Artefactos clave

- Modificación de `/root/.ssh/authorized_keys`.
- Cambios sospechosos en archivos de configuración.

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en `authorized_keys`?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

UsePAM

Descripción ampliada

Deshabilitar PAM reduce significativamente los controles de autenticación disponibles, incluyendo políticas de bloqueo, expiración de contraseña, autenticación multifactor y controles adicionales de seguridad. Esto debilita el proceso de autenticación y facilita ataques de fuerza bruta o abuso de cuentas comprometidas.

Importancia defensiva

PAM añade controles avanzados de autenticación.

Evidencia

Línea 147: UsePAM no

Explotación del hallazgo

MITRE ATT&CK

ID	Técnica	Táctica
T1556	Modify Authentication Process	Credential Access, Persistence
T1110	Brute Force	Credential Access

Cyber Kill Chain

Fase

Indicadores DFIR

Tipo	Detalles
Logs relacionados	
Artefactos clave	

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

KexAlgorithms

Descripción ampliada

El uso de algoritmos de intercambio de claves débiles como versiones basadas en SHA-1 puede permitir ataques de degradación criptográfica o facilitar ataques Man-in-the-Middle. Un algoritmo KEX inseguro compromete la confidencialidad inicial del túnel SSH, poniendo en riesgo credenciales y datos transmitidos.

Importancia defensiva

Usar Algoritmos Kex inseguros puedes exponer las conexiones a posibles ataques 'Man In The Middle'

Evidencia

Se encontró el KexAlgorithm inseguro: diffie-hellman-group1-sha1

Explotación del hallazgo

MITRE ATT&CK

ID	Técnica	Táctica
T1557	Adversary-in-the-Middle	Credential Access, Collection
T1040	Network Sniffing	Credential Access, Discovery

Cyber Kill Chain

Fase

Indicadores DFIR

Tipo	Detalles
Logs relacionados	
Artefactos clave	

Checklist Forense

- ¿Hay accesos SSH exitosos desde IPs externas o desconocidas?
- ¿Se detectan múltiples intentos fallidos consecutivos?
- ¿Existen modificaciones recientes en authorized_keys?
- ¿Se han creado nuevos usuarios o claves SSH?
- ¿Hay procesos sospechosos ejecutándose bajo root?
- ¿Se han observado sesiones SSH activas fuera de horario?
- ¿Aparecen túneles SSH o conexiones reenviadas inesperadas?

Fin del Playbook

Este documento recoge un análisis avanzado destinado a apoyar investigaciones forenses, threat hunting y respuesta ante incidentes basados en los hallazgos detectados durante la auditoría de seguridad SSH.

Para remediaciones completas y validación posterior, consulte el informe principal generado por GoAudit.